

애플리케이션 보안

Kali Linux 침투테스트 기본 과정

Kali Linux를 활용한 기본적인 침투테스트(Penetration Testing) 과정을 정리한 학습 기록입니다.

실습은 허가된 교육 환경, CTF, 워게임 및 테스트 시스템을 기준으로 합니다.

학습 목표

이번 학습에서는 Kali Linux에서 제공하는 대표적인 보안 도구를 활용하여 대상 시스템의 정보를 수집하고, 알려진 취약점을 분석하며, 웹 애플리케이션의 보안 설정을 점검하는 기본적인 침투테스트 과정을 학습했습니다.

주요 학습 도구는 다음과 같습니다.

- Nmap
- SearchSploit
- Metasploit Framework
- msfvenom
- DirBuster
- Nikto
- Burp Suite

전체적인 과정은 다음과 같습니다.

```
정보 수집
↓
포트 및 서비스 탐지
↓
서비스 버전 확인
↓
취약점 조사
↓
취약점 검증
↓
세션 및 권한 확인
```

1. Nmap

Nmap이란?

Nmap(Network Mapper)은 네트워크에 연결된 시스템의 **포트, 서비스, 운영체제 및 네트워크 정보를 탐색하는 도구**입니다.

침투테스트에서는 공격을 수행하기 전에 대상 시스템의 공격 표면(Attack Surface)을 파악하는 과정에서 사용합니다.

기본 스캔

```
sudo nmap -sV <대상 IP>
```

주요 옵션

옵션	설명
-sV	실행 중인 서비스 및 버전 탐지
-p	특정 포트 지정
-sC	기본 NSE 스크립트 실행
-p-	전체 TCP 포트 스캔

특정 포트 확인

FTP의 기본 포트인 21번을 확인할 경우:

```
sudo nmap -p 21 -sV <대상 IP>
```

여러 포트를 동시에 확인할 수도 있습니다.

```
sudo nmap -p 80,443 -sV <대상 IP>
```

전체 포트 확인

서비스가 기본 포트를 사용하지 않는 경우를 고려하여 전체 TCP 포트를 확인할 수 있습니다.

```
sudo nmap -p- -sV <대상 IP>
```

이를 통해 일반적으로 사용하는 포트뿐만 아니라 다른 포트에서 실행 중인 서비스도 확인할 수 있습니다.

2. 서비스 버전 기반 취약점 조사

Nmap을 이용하면 대상 시스템에서 실행 중인 서비스와 버전을 확인할 수 있습니다.

예를 들어:

```
21/tcp  
vsftpd 2.3.4
```

와 같은 결과를 확인했다면 해당 버전에서 알려진 취약점이 존재하는지 조사할 수 있습니다.

SearchSploit

SearchSploit은 Exploit Database의 공개 취약점 정보를 로컬에서 검색할 수 있는 도구입니다.

```
searchsploit <서비스/버전>
```

예:

```
searchsploit vsftpd 2.3.4
```

검색 결과를 통해 다음과 같은 정보를 확인할 수 있습니다.

- 취약점 존재 여부
- 관련 CVE
- 공개된 Exploit
- 취약점 유형

- 참고할 수 있는 기술 정보

중요한 점

서비스 버전이 일치한다고 해서 반드시 취약하다고 판단해서는 안 됩니다.

실제 취약점 여부는 다음과 같은 요소를 함께 확인해야 합니다.

- 정확한 버전
- 패치 여부
- 운영체제
- 서비스 설정
- 취약점의 전제 조건
- 실제 환경에서의 재현 여부

3. Metasploit Framework

Metasploit Framework는 취약점 검증과 보안 테스트에 사용되는 대표적인 침투테스트 프레임워크입니다.

허가된 테스트 환경에서 알려진 취약점의 영향을 검증할 수 있습니다.

Metasploit 실행

```
sudo msfconsole
```

모듈 검색

Nmap이나 SearchSploit에서 확인한 서비스 정보를 기반으로 관련 모듈을 검색합니다.

```
search <서비스/버전>
```

예:

```
search vsftpd 2.3.4
```

모듈 선택

검색 결과에서 사용할 모듈을 선택합니다.

```
use <모듈 번호>
```

모듈 옵션 확인

```
show options
```

현재 모듈에서 필요한 설정값을 확인할 수 있습니다.

대상 지정

```
set RHOSTS <대상 IP>
```

필요한 경우 포트 등의 추가 옵션도 설정합니다.

```
set RPORT <대상 포트>
```

설정을 완료한 후 허가된 실습 환경에서 취약점 검증을 수행합니다.

```
exploit
```

4. 세션 및 권한 확인

취약점 검증이 성공하여 세션이 생성된 경우 현재 세션의 권한과 시스템 정보를 확인할 수 있습니다.

Linux 환경에서는 다음 명령을 사용할 수 있습니다.

```
id
```

예:

```
uid=0(root)
```

`uid=0` 은 Linux에서 root 사용자를 의미합니다.

권한 확인의 의미

침투테스트에서 중요한 것은 단순히 "root 권한을 얻었다"는 결과가 아닙니다.

취약점으로 인해 공격자가 **어느 수준의 권한과 접근 범위를 확보할 수 있는지**를 확인하고, 이를 보안 위험으로 평가하는 것이 중요합니다.

예를 들어:

```
일반 사용자 권한
↓
서비스 계정 권한
↓
관리자 권한
```

권한이 상승할수록 시스템에 미칠 수 있는 영향도 커집니다.

5. RHOSTS와 LHOST

Metasploit이나 Reverse Shell을 학습할 때 자주 사용하는 개념입니다.

RHOSTS

`RHOSTS` 는 **Remote Hosts**를 의미합니다.

즉, 테스트 대상 시스템의 주소입니다.

```
RHOSTS = 대상 시스템 IP
```

LHOST

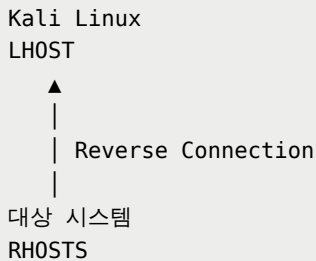
`LHOST` 는 **Local Host**를 의미합니다.

일반적으로 Reverse Connection을 받는 Kali Linux의 IP 주소를 지정합니다.

LHOST = Kali Linux IP

Reverse Connection 개념

Reverse Shell과 같은 구조에서는 대상 시스템이 외부에서 직접 연결을 받는 것이 아니라 테스트 머신을 향해 연결을 생성합니다.



실습 환경에서는 반드시 본인이 통제하거나 허가받은 시스템에서만 사용해야 합니다.

6. msfvenom

`msfvenom` 은 Metasploit Framework에서 제공하는 **Payload 생성 도구**입니다.

Payload는 취약점이 성공한 이후 실행되는 동작을 의미합니다.

기본적인 구조는 다음과 같습니다.

```
msfvenom -p <payload> LHOST=<Kali IP> LPORT=<포트> -f <형식>
```

Payload 예시

PHP 환경을 대상으로 하는 Meterpreter Reverse TCP Payload의 형태는 다음과 같습니다.

```
php/meterpreter/reverse_tcp
```

각 부분은 다음과 같은 의미를 가집니다.

구성	의미
php	PHP 환경을 대상으로 하는 Payload
meterpreter	Metasploit의 세션 기능
reverse_tcp	대상에서 테스트 머신으로 역방향 TCP 연결

Payload를 생성하는 것 자체보다 **어떤 환경에서 어떤 Payload가 필요한지 판단하는 과정**이 중요합니다.

Web 취약점 점검

웹 애플리케이션을 대상으로 하는 침투테스트에서는 네트워크 스캔뿐만 아니라 웹 서버와 애플리케이션의 구조 및 설정을 확인해야 합니다.

```

웹 서버
↓
정보 수집
↓
디렉터리 및 파일 탐색
↓
웹 서버 취약점 점검
↓
HTTP 요청 분석
↓
취약한 기능 검증

```

7. DirBuster

DirBuster는 웹 서버에 존재할 수 있는 **숨겨진 디렉터리와 파일을 탐색하는 도구**입니다.

웹 서버가 외부에 공개하지 않았다고 생각한 경로가 실제로 존재하는지 확인하는 데 활용할 수 있습니다.

```

웹 서버
↓
DirBuster
↓
Directory / File Enumeration
↓
숨겨진 경로 확인

```

예를 들어 다음과 같은 경로가 발견될 수 있습니다.


```
/admin
/backup
/uploads
/test
```

발견된 경로는 이후 수동으로 접근하여 어떤 기능을 제공하는지 분석할 수 있습니다.

8. Nikto

Nikto는 웹 서버의 알려진 취약점이나 잘못된 설정 등을 점검하는 웹 서버 스캐너입니다.

```
Nikto
↓
웹 서버 정보 수집
↓
설정 및 알려진 문제 확인
↓
추가 분석 대상 식별
```

점검할 수 있는 항목의 예시는 다음과 같습니다.

- 위험한 HTTP 설정
- 알려진 취약점
- 기본 파일
- 노출된 경로
- 오래된 서버 구성
- 보안상 문제가 될 수 있는 설정

Nikto의 결과 역시 자동으로 취약점이라고 확정하기보다는 추가적인 수동 검증이 필요합니다.

9. Burp Suite

Burp Suite는 웹 애플리케이션의 HTTP/HTTPS 요청과 응답을 분석하는 대표적인 웹 보안 테스트 도구입니다.

웹 브라우저와 서버 사이의 통신을 확인하고 요청을 수정하여 애플리케이션의 동작을 분석할 수 있습니다.

```
Browser
↓
Burp Suite
↓
Web Server
```

HTTP 요청 분석

대표적인 HTTP Method는 다음과 같습니다.

```
GET
POST
PUT
DELETE
```

각 요청의 다음 요소를 확인할 수 있습니다.

- HTTP Method
- URL
- Header
- Cookie
- Parameter
- Request Body
- Response

10. HTTP Method 점검

웹 서버가 필요 이상의 HTTP Method를 허용하고 있는지 확인할 수 있습니다.

예를 들어 WebDAV가 활성화된 환경에서는 다음과 같은 Method가 사용될 수 있습니다.

```
PUT
DELETE
```

중요한 것은 단순히 Method가 허용되는지 확인하는 것에서 끝나는 것이 아니라 **허용된 Method가 실제 서비스에서 필요한지, 잘못된 파일 업로드나 삭제 등의 보안 문제로 이어질 수 있는지를 분석하는 것**입니다.

11. 전체 침투테스트 흐름

기본적인 시스템 점검

```
Nmap
↓
포트 탐색
↓
서비스 탐지
↓
서비스 버전 확인
↓
SearchSploit
↓
알려진 취약점 조사
↓
Metasploit
↓
관련 모듈 검색
↓
show options
↓
RHOSTS 등 설정
↓
취약점 검증
↓
세션 확인
↓
권한 및 영향 분석
```

웹 애플리케이션 점검

```
웹 서버 탐색
↓
DirBuster / Nikto
↓
디렉터리 및 파일 정보 수집
↓
Burp Suite
↓
HTTP 요청 및 응답 분석
↓
Cookie / Parameter / Method 확인
↓
취약한 기능 식별
↓
```

허가된 환경에서 취약점 검증
↓
영향 및 대응 방법 분석

12. 핵심 개념 정리

도구	주요 목적
Nmap	포트 및 서비스 탐색
SearchSploit	공개된 Exploit 및 취약점 검색
Metasploit	취약점 검증 및 보안 테스트
msfvenom	Metasploit Payload 생성
DirBuster	웹 디렉터리 및 파일 탐색
Nikto	웹 서버 취약점 및 설정 점검
Burp Suite	HTTP/HTTPS 요청 및 응답 분석

13. 주요 개념 정리

개념	의미
RHOSTS	원격 대상 시스템
LHOST	로컬 테스트 시스템
LPORT	로컬에서 연결을 수신할 포트
Payload	취약점 검증 이후 실행되는 코드 또는 동작
Session	취약점 검증 후 생성된 원격 세션
Exploit	취약점을 이용하여 의도하지 않은 동작을 유발하는 코드 또는 방법
Attack Surface	공격자가 접근할 수 있는 시스템의 노출 영역
Enumeration	시스템이나 서비스의 상세 정보를 수집하는 과정

14. 침투테스트에서 중요한 사고 과정

도구의 명령어를 외우는 것보다 왜 해당 도구를 사용하는지 이해하는 것이 중요합니다.

포트가 열려 있다
↓

어떤 서비스인가?
↓
어떤 버전인가?
↓
알려진 취약점이 존재하는가?
↓
실제 환경에서 재현 가능한가?
↓
어떤 영향이 발생하는가?
↓
어떻게 보완할 수 있는가?

예를 들어 Nmap에서 다음 결과를 확인했다고 가정합니다.

```
21/tcp  
vsftpd 2.3.4
```

단순히 "21번 포트가 열려 있다"에서 끝나는 것이 아니라:

FTP 서비스 발견
↓
vsftpd 버전 확인
↓
SearchSploit로 취약점 조사
↓
관련 CVE 및 조건 확인
↓
허가된 실습 환경에서 검증
↓
취약점의 영향 분석
↓
패치 및 접근 제어 방법 확인

과 같은 사고방식으로 접근해야 합니다.

15. 보안 관점에서의 대응

침투테스트는 공격 방법을 확인하는 것뿐만 아니라 **발견된 문제를 어떻게 해결할 것인지 확인하는 과정**이기도 합니다.

네트워크

- 사용하지 않는 포트 차단
- 불필요한 서비스 제거

- 방화벽 정책 최소화
- 외부 접근이 필요한 서비스만 공개

서비스

- 최신 보안 패치 적용
- 오래된 버전 사용 금지
- 기본 계정 및 설정 변경
- 서비스 권한 최소화

웹 서버

- 불필요한 HTTP Method 비활성화
- 디렉터리 노출 방지
- 민감한 파일 외부 접근 차단
- 보안 헤더 및 접근 제어 설정

웹 애플리케이션

- 사용자 입력 검증
- 인증 및 인가 강화
- 세션 및 Cookie 보안 강화
- 서버 측 검증 적용
- 로그 및 모니터링 활성화

16. 오늘 배운 점

- Nmap을 이용하면 대상 시스템의 열린 포트와 실행 중인 서비스를 파악할 수 있다.
- 서비스의 정확한 버전을 확인하면 알려진 취약점 조사에 활용할 수 있다.
- SearchSploit을 통해 공개된 취약점과 Exploit 정보를 빠르게 검색할 수 있다.
- Metasploit은 취약점의 존재와 영향을 검증하는 데 사용할 수 있다.
- `RHOSTS` 는 대상 시스템을 의미하고 `LHOST` 는 테스트를 수행하는 로컬 시스템을 의미한다.
- `msfvenom` 은 Metasploit에서 사용할 Payload를 생성하는 도구이다.

- 웹 애플리케이션에서는 네트워크 포트뿐만 아니라 숨겨진 디렉터리, HTTP Method, Parameter, Cookie 등의 요소도 분석해야 한다.
 - DirBuster와 Nikto를 이용하면 웹 서버의 노출된 경로와 알려진 보안 문제를 확인할 수 있다.
 - Burp Suite를 사용하면 브라우저와 서버 사이의 HTTP/HTTPS 통신을 직접 분석할 수 있다.
 - 침투테스트에서는 단순히 취약점을 찾는 것보다 **취약점의 원인, 재현 조건, 영향 범위 및 대응 방법까지 분석하는 과정이 중요하다.**
 - 모든 취약점 검증은 허가된 CTF, 워게임, 실습 서버 또는 보안 평가 범위 내에서 수행해야 한다.
-

참고 자료

- Kali Linux 공식 문서
- Nmap 공식 문서
- Metasploit Documentation
- Exploit Database / SearchSploit
- PortSwigger Web Security Academy
- OWASP Web Security Testing Guide
- OWASP Top 10